

Лекция 8. Построение системы защиты от угрозы нарушения целостности и доступности информации

Учебные вопросы:

1. Методы и технологии обеспечения целостности информации
2. Методы и технологии обеспечения доступности (сохранности) данных

1. Методы и технологии обеспечения целостности информации

Понятие целостности данных в научной литературе имеет несколько определений. В одной из наиболее распространенных трактовок под целостностью данных подразумевается отсутствие ненадлежащих изменений. Смысл понятия «ненадлежащее изменение» раскрывается Д. Кларком и Д. Вилсоном: ни одному пользователю автоматизированной системы, в том числе и авторизованному, не должны быть разрешены такие изменения данных, которые повлекут за собой их разрушение или потерю.



Нарушение целостности информации происходит либо при несанкционированном доступе к информации, либо без него. Угроза целостности существует на всех этапах жизни информации:

- ~ при хранении;
- ~ обработке;
- ~ транспортировке.

В информационной системе основное место хранения

информации — электронные носители.

Определяя порядок хранения информации на электронных носителях, следует иметь в виду, что от состояния носителей зависит качество программ и защищаемых данных. Электронные носители являются устройствами, подвергающимися интенсивному износу. Кроме того, в электронные носители могут быть внедрены закладки, поэтому используемые методы записи, хранения и считывания нельзя считать защищенными.

Организационно-технологические меры защиты целостности информации на электронных носителях можно разделить на две основные группы:

- ~ организационные меры по поддержке целостности информации;
- ~ технологические меры контроля целостности битовых последовательностей.

Организационные меры защиты направлены на предупреждение хищения или утраты носителей, а вместе с ними и информации. Организационные меры излагаются в документах, описывающих режим хранения конфиденциальной информации.

Организационные меры разделяются на две группы:

- ~ создание резервных копий информации, хранимой на электронных носителях;
- ~ обеспечение правильных условий хранения и эксплуатации носителей.

Создание резервных копий

Создание резервных копий информации, хранимой в информационной системе, должно быть обязательной регулярной процедурой, периодичность которой зависит от важности информации и технологии ее обработки, в частности от объема вводимых данных, возможности повторного ввода и т. д. Для создания резервных копий

могут использоваться как стандартные утилиты, так и специализированные системы резервного копирования, адаптированные к конкретной системе.

При ведении резервных копий необходимо регулярно проверять сохранность и целостность находящейся в них информации.

Обеспечение правильных условий хранения и эксплуатации

Обеспечение правильных условий хранения и эксплуатации определяется конкретным типом носителя.

Регистрация и учет носителей производятся независимо от того, есть ли на них конфиденциальная информация или нет. Служебные носители должны иметь ясную, хорошо видимую этикетку, на которой проставлены гриф, номер, дата регистрации. Гриф секретности носителя может изменяться только в большую сторону, т. к. информация не может быть гарантированно удалена. Учет носителей по журналу ведется в течение всей «жизни» носителя. В помещении не должно быть личных носителей. Не допускается работа с непроверенными носителями. Должна проводиться систематическая комиссионная проверка наличия носителей и информации.

Хранение электронных носителей такое же, как обычных документов такого же уровня конфиденциальности. Основное требование при хранении — исключение НСД. Передача между подразделениями должна осуществляться под расписку и учитываться в журнале. Вынос за пределы помещения возможен только с разрешения уполномоченных лиц.

Жесткий диск регистрируется с грифом, соответствующим категории компьютера, независимо от целей его использования. На корпусе жесткого диска должна быть соответствующая этикетка. При передаче компьютера в ремонт необходимо либо изъять жесткий диск, либо гарантированно удалить с него информацию, либо

присутствовать при ремонте.

Копирование файлов с зарегистрированных электронных носителей допускается только на компьютерах, категория которых не ниже грифа секретности носителя. Каждое копирование должно учитываться в обычном или электронном журнале.

Следует уделять особое внимание удалению информации с носителей. Обычные способы удаления файлов не приводят к удалению области данных, происходит стирание только на логическом уровне. Кроме того, при удалении следует учесть, что в современных средствах обработки информация существует в нескольких экземплярах, под разными именами.

Рассмотрим теперь технологические меры контроля целостности битовых последовательностей, хранящихся на электронных носителях. Целостность информации в областях данных проверяется с помощью контрольного кода, контрольные числа которого записываются после соответствующих областей, причем в контролируемую область включаются соответствующие маркеры.

Для обеспечения контроля целостности информации чаще всего применяют циклический контрольный код. Этот метод, дающий хорошие результаты при защите от воздействия случайных факторов (помех, сбоев и отказов), совсем не обладает имитостойкостью, т. е. не обеспечивает защиту от целенаправленных воздействий нарушителя, приводящих к навязыванию ложных данных.

Для контроля целостности можно использовать методы имитозащиты, основанные на криптографических преобразованиях. Они обеспечивают надежный контроль данных, хранящихся в системе, но в то же время реализуются в виде объемных программ и требуют значительных вычислительных ресурсов.

При рассмотрении вопроса целостности данных при обработке используется интегрированный подход, основанный на ряде работ Д.

Кларка и Д. Вилсона, а также их последователей и оппонентов и включающий в себя девять теоретических принципов:

- ~ корректность транзакций;
- ~ аутентификация пользователей;
- ~ минимизация привилегий;
- ~ разграничение функциональных обязанностей;
- ~ аудит произошедших событий;
- ~ объективный контроль;
- ~ управление передачей привилегий;
- ~ обеспечение непрерывной работоспособности;
- ~ простота использования защитных механизмов.

Понятие *корректности транзакций* определяется следующим образом. Пользователь не должен модифицировать данные произвольно, а только определенными способами, т. е. так, чтобы сохранялась целостность данных. Другими словами, данные можно изменять только путем корректных транзакций и нельзя произвольными средствами. Кроме того, предполагается, что «корректность» каждой из таких транзакций может быть некоторым способом доказана.

Второй принцип гласит, что изменение данных может осуществляться только специально *аутентифицированными* для этой цели пользователями. Данный принцип работает совместно с последующими четырьмя, с которыми тесно связана его роль в общей схеме обеспечения целостности.

Идея минимизации привилегий появилась еще на ранних этапах развития информационной безопасности в форме ограничения, накладываемого на возможности выполняющихся в системе процессов и подразумевающего то, что процессы должны быть наделены теми и только теми привилегиями, которые естественно и минимально необходимы для выполнения процессов. Принцип минимизации привилегий распространяется и на программы, и на пользователей.

Пользователи имеют, как правило, несколько больше привилегий, чем им необходимо для выполнения конкретного действия в данный момент времени. А это открывает возможности для злоупотреблений. *Разграничение функциональных обязанностей* подразумевает организацию работы с данными таким образом, что в каждой из ключевых стадий, составляющих единый критически важный, с точки зрения целостности, процесс, необходимо участие различных пользователей. Это гарантирует невозможность выполнения одним пользователем всего процесса целиком (или даже двух его стадий) с тем, чтобы нарушить целостность данных.

Аудит произошедших событий, включая возможность восстановления полной картины происшедшего, является превентивной мерой в отношении потенциальных нарушителей.

Принцип *объективного контроля* также является одним из краеугольных камней политики контроля целостности. Суть данного принципа заключается в том, что контроль целостности данных имеет смысл лишь тогда, когда эти данные отражают реальное положение вещей. В связи с этим Кларк и Вилсон указывают на необходимость регулярных проверок, имеющих целью выявление возможных несоответствий между защищаемыми данными и объективной реальностью, которую они отражают.

Управление передачей привилегий необходимо для эффективной работы всей политики безопасности. Если схема назначения привилегий неадекватно отражает организационную структуру предприятия или не позволяет администраторам безопасности гибко манипулировать ею для обеспечения эффективности производственной деятельности, защита становится обременительной и провоцирует попытки обойти ее.

Принцип *обеспечения непрерывной работы* включает защиту от сбоев, стихийных бедствий и других форс-мажорных обстоятельств.

Простота использования защитных механизмов необходима, в том числе для того, чтобы пользователи не стремились обойти их как мешающих «нормальной» работе. Кроме того, как правило, простые схемы являются более надежными. Простота использования защитных механизмов подразумевает, что самый безопасный путь эксплуатации системы будет также наиболее простым, и наоборот, самый простой — наиболее защищенным.

Средства контроля целостности должны обеспечивать защиту от несанкционированного изменения информации нарушителем при ее передаче по каналам связи.

При транспортировке информации следует защищать как целостность, так и подлинность информации.

Схема контроля целостности данных подразумевает выполнение двумя сторонами — *источником* и *приемником* — некоторых (возможно, разных) криптографических преобразований данных. Источник преобразует исходные данные и передает их приемнику вместе с некоторым приложением, обеспечивающим избыточность шифрограммы.

Приемник обрабатывает полученное сообщение, отделяет приложение от основного текста и проверяет их взаимное соответствие, осуществляя таким образом контроль целостности.

Контроль целостности может выполняться с *восстановлением* или *без восстановления* исходных данных.

Целостность отдельного сообщения обеспечивается имитовставкой, ЭЦП или шифрованием, целостность потока сообщений — соответствующим механизмом целостности.

Имитовставка

Для обеспечения целостности в текст сообщения часто вводится некоторая дополнительная информация, которая легко вычисляется,

если секретный ключ известен, и является трудно вычислимой в противном случае. Если такая информация вырабатывается и проверяется с помощью одного и того же секретного ключа, то ее называют *имитовставкой* (в зарубежных источниках используется термин *код аутентификации сообщений* — Message Authentication Code (MAC) — поскольку помимо целостности может обеспечиваться еще и аутентификация объекта). Имитовставкой может служить значение хэш-функции, зависящей от секретного ключа, или выходные данные алгоритма шифрования в режиме сцепления блоков шифра.

Шифрование

Целостность данных можно обеспечить и с помощью их шифрования симметричным криптографическим алгоритмом при условии, что подлежащий защите текст обладает некоторой избыточностью. Последняя необходима для того, чтобы нарушитель, не зная ключа шифрования, не смог бы создать шифrogramму, которая после расшифрования успешно прошла бы проверку целостности.

Избыточности можно достигнуть многими способами. В одних случаях текст может обладать достаточной естественной избыточностью (например, в тексте, написанном на любом языке, разные буквы и буквосочетания встречаются с разной частотой). В других можно присоединить к тексту до шифрования некоторое контрольное значение, которое, в отличие от имитовставки и цифровой подписи, не обязательно должно вырабатываться криптографическими алгоритмами, а может представлять собой просто последовательность заранее определенных символов.

Контроль целостности потока сообщений

Контроль целостности потока сообщений помогает обнаружить их повтор, задержку, переупорядочение или утрату. Предполагается, что

целостность каждого отдельного сообщения обеспечивается шифрованием, имитовставкой или цифровой подписью. Для контроля целостности потока сообщений можно, например:

- ~ присвоить сообщению *порядковый номер целостности*;
- ~ использовать в алгоритмах шифрования *сцепление* с предыдущим сообщением.

При использовании порядкового номера целостности, который может включать в себя порядковый номер сообщения и имя источника, приемник хранит последний номер принятого сообщения каждого источника. Для контроля целостности приемник проверяет, например, что порядковый номер целостности текущего сообщения от данного источника на единицу больше номера предыдущего сообщения. Если в качестве порядкового номера целостности используется время отправки сообщения, то проверяется, действительно ли время отправки и время приема близки друг к другу с точностью до задержки сообщения в канале связи и разности хода часов источника и приемника.

Электронная подпись

Термин «электронная подпись» (ЭЦП) используется для методов, позволяющих устанавливать подлинность автора сообщения при возникновении спора относительно авторства этого сообщения. ЭЦП применяется в информационных системах, в которых отсутствует взаимное доверие сторон (финансовые системы, системы контроля за соблюдением международных договоров и др.). Концепцию цифровой подписи для аутентификации информации предложили Диффи и Хеллман в 1976 г. Она заключается в том, что каждый абонент сети имеет личный секретный ключ, на котором он формирует подпись и известную всем другим абонентам сети проверочную комбинацию, необходимую для проверки подписи (эту проверочную комбинацию

иногда называют открытым ключом). Цифровая подпись вычисляется на основе сообщения и секретного ключа отправителя. Любой получатель, имеющий соответствующую проверочную комбинацию, может аутентифицировать сообщение по подписи.

ЭЦП в цифровых документах играет ту же роль, что и подпись, поставленная от руки в документах, которые напечатаны на бумаге: это данные, присоединяемые к передаваемому сообщению и подтверждающие, что отправитель (владелец подписи) составил или заверил данное сообщение. Получатель сообщения или третья сторона с помощью цифровой подписи может проверить, что автором сообщения является именно владелец подписи (т. е. аутентифицировать источник данных) и что в процессе передачи не была нарушена целостность полученных данных.

Если пользователь ведет себя грамотно, с точки зрения соблюдения норм секретности (хранение секретных ключей подписи, работа с «чистым» программным продуктом, осуществляющим функции подписи), и тем самым исключает возможность похищения ключей или несанкционированного изменения данных и программ, то стойкость системы подписи определяется исключительно криптографическими качествами.

2. Методы и технологии обеспечения доступности (сохранности) данных

Поскольку одной из основных задач информационной системы является своевременное обеспечение пользователей системы необходимой информацией (сведениями, данными, управляющими воздействиями и т. п.), то угроза отказа доступа к информации может еще рассматриваться как угроза отказа в обслуживании или угроза отказа функционирования.



Часто невозможно бывает разделить причины отказа. В связи с этим вводят понятие надежности. Надежность — свойство объекта сохранять во времени значения всех параметров, характеризующих способность выполнять требуемые функции в заданных режимах и условиях применения, технического обслуживания, ремонта, хранения и транспортировки. Для оценки надежности функционирования информационной системы не важно, вызваны ли отказы действиями злоумышленника или связаны с ошибками разработки, важно, как и в каком объеме произойдет их парирование.

Целесообразно проводить отдельно оценку надежности аппаратуры и программного обеспечения, так как подход к определению надежности здесь различен.

Оценка *надежности оборудования* основана на следующем подходе.

Элементная надежность любого устройства или системы в целом оценивается как произведение вероятности безотказной работы $P'(t)$ на коэффициент готовности K_r :

$$P_0(t) = P'(t)K_r.$$

Если надежность выступает в качестве одной из мер эффективности системы, то оптимальным ее значением является такое, при котором стоимость эксплуатации является минимальной. Оптимальное значение показателя надежности может быть оценено графически (Рисунок 1).

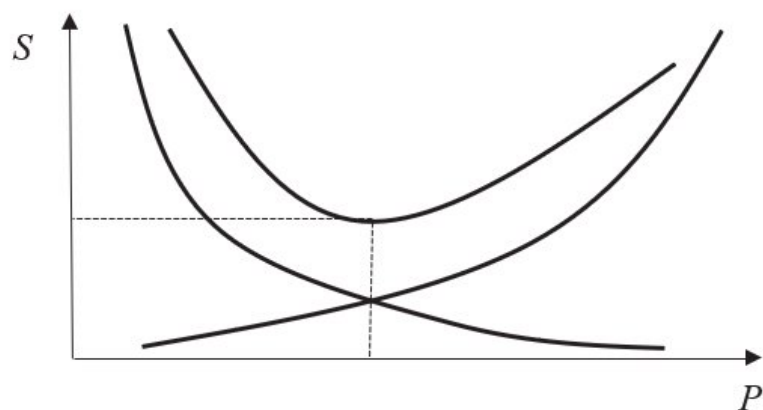


Рис. 1. Зависимость затрат от надежности:

$S_э$ — эксплуатационные затраты; S_p — затраты на разработку

В некоторых случаях решается задача достижения максимальной надежности при фиксированных затратах или других закрепленных условиях.

Для определения надежности существуют как теоретические методы расчета, так и рабочие методики. Именно на основе таких расчетов вырабатываются практические мероприятия по повышению надежности работы как отдельных элементов, так и систем в целом.

На начальной стадии проектирования чаще всего используются рабочие методики, основанные на простых моделях, или элементарные методики расчета надежности, исходящие из предположения о самостоятельности отдельных элементов. В теоретических методах расчета надежности наиболее широкое распространение получили методики расчета по элементам. При этом функциональные зависимости и параметры, характеризующие надежность работы отдельного элемента, могут быть выражены следующими формулами:

частота отказов

$$f(t) = dq(t)/dt = - dP(t)/dt;$$

интенсивность отказов

$$\lambda(t) = \frac{1}{P(t)} \frac{d q(t)}{dt} = - \frac{1}{P(t)} \frac{dP(t)}{dt},$$

среднее время безотказной работы

$$t_{cp} = \int_0^{\infty} t \cdot f(t) dt,$$

где P — вероятность безотказной работы элемента; q — вероятность отказа элемента.

Эти формулы применимы к системам с любым числом элементов и произвольным их отношением.

Вероятность безотказной работы системы является функцией вероятностей безотказной работы входящих в систему элементов

$$P_c = f_1 [P_1(t), P_2(t), \dots, P_n(t)].$$

Взаимосвязь функций для отдельных элементов может быть разной. В частности, вероятность безотказной работы или функция надежности системы, состоящей из n произвольно соединенных элементов, может быть выражена в виде полинома

$$P_c = \sum_{i=1}^k a_i P_i.$$

В случае независимого влияния отдельных элементов на работоспособность установки, если отказ каждого из элементов приводит к отказу всей системы, схема структурных надежных отношений представляется в виде последовательного соединения элементов. В этом случае вероятность безотказной работы системы определяется произведением вероятностей безотказной работы элементов

$$P_c(t) = \prod_{i=1}^n P_i(t).$$

Если же элементы влияют друг на друга, то схема структурных надежных отношений будет параллельной или смешанной. Если отказ элемента не приводит к отказу системы, то в схеме структурных надежных отношений этот элемент включается параллельно, а при вычислении надежности системы перемножаются вероятности отказов параллельных элементов и полученное произведение вычитается из единицы:

$$P_c(t) = 1 - \prod_{j=1}^n (1 - P_j(t)).$$

Надежность работы элементов не всегда удобно характеризовать вероятностью безотказной работы, так как для малых периодов времени работы элементов значения $P_i(t)$ будут близкими к единице. В этом случае лучше использовать интенсивность отказов, которая характеризует плотность вероятности появления отказа отдельно взятого элемента. Она определяется количеством отказов n_i в единицу времени Δt , отнесенных к количеству исправно работающих в данный момент однотипных элементов N , то есть

$$\lambda = \frac{n_i}{N \Delta t}.$$

Вероятность безотказной работы связана с интенсивностью отказов следующим соотношением:

$$P(t) = \exp\left(-\int_0^t \lambda(t) dt\right).$$

Функция $\lambda(t)$ имеет вид, изображенный на рис. 2.

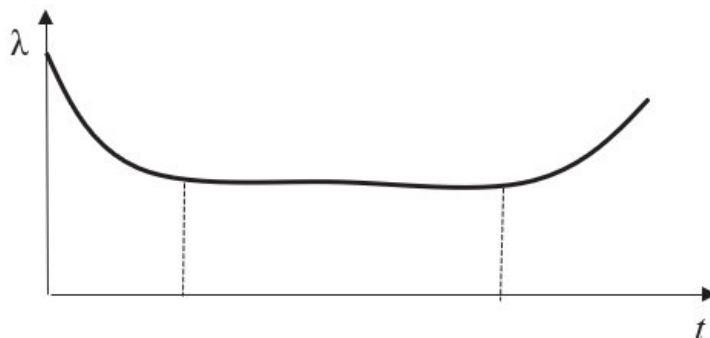


Рис. 2. Изменение интенсивности отказов системы в течение срока службы

Первый участок повышенной интенсивности отказов характеризует период, отказы в котором возникают главным образом в результате скрытых неисправностей, допущенных при проектировании, нарушении технологии изготовления системы или связанных с трудностями освоения эксплуатации. Наиболее длительное время система эксплуатируется в нормальных условиях (участок II). Именно этот период работы системы принимается во внимание при расчете надежности в процессе проектирования. Участок III характеризует период увеличения интенсивности отказов вследствие износа оборудования и его старения.

Анализ работы многочисленных технических устройств показал: чем они проще, тем более надежны.

При обеспечении защиты информационной системы от угрозы отказа функционирования обычно считается, что надежность аппаратных компонентов достаточно высока и данной составляющей в общей надежности можно пренебречь. Это связано с тем, что темпы морального старения вычислительной техники значительно опережают

темпы ее физического старения и замена вычислительной техники, как правило, происходит до ее выхода из строя.

Таким образом, на надежность функционирования информационной системы во многом влияет *надежность функционирования программного обеспечения*, входящего в ее состав.

Несмотря на явное сходство в определениях надежности для аппаратных средств и программного обеспечения, фактически последнее имеет принципиальные отличия:

- ~ программа в большинстве случаев не может отказать случайно;
- ~ ошибки в программном обеспечении, допущенные при его создании, зависят от технологии разработки, организации работ и квалификации исполнителей;
- ~ ошибки не являются функцией времени;
- ~ причиной отказов является набор входных данных, сложившихся к моменту отказа.

Существует два основных подхода к обеспечению защиты программного обеспечения от угрозы отказа функционирования:

- ~ обеспечение отказоустойчивости программного обеспечения;
- ~ предотвращение неисправностей.

Отказоустойчивость предусматривает, что оставшиеся ошибки программного обеспечения обнаруживаются во время выполнения программы и парируются за счет использования программной, информационной и временной избыточности. Предотвращение неисправностей связано с анализом природы ошибок, возникающих на разных фазах создания программного обеспечения, и причин их возникновения.